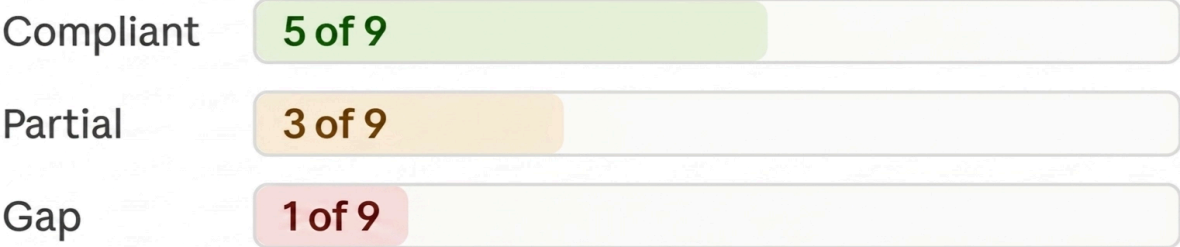


GLBA Gap Assessment

3.1 Executive Summary

Tri-State Community Bancorp's information security program was assessed against the 9 required elements of the FTC's GLBA Safeguards Rule. Of the 9 elements, 5 are fully in place, 3 are partially in place, and 1 represents a notable gap. The most significant finding is the absence of a documented, repeatable process for overseeing service provider security, a gap that also affects the institution's third-party risk posture identified in the risk register above. Priority recommendations are: (1) formalize the vendor security oversight process, (2) complete encryption at rest across all data stores, and (3) establish a recurring tabletop testing cadence for the incident response plan.

GLBA SAFEGUARDS RULE — 9 ELEMENTS ASSESSED



Priority finding: service provider oversight (High)

3.2 Gap Assessment Detail

Gap Assessment Detail (Database)

Aa Safeguards Rule Element	≡ Current State	📍 Severity	≡ Recommendation
<u>Report to the board or governing body</u>	Compliant — quarterly risk committee reporting	—	None
<u>Maintain an incident response plan</u>	Partial — plan exists; tabletop testing overdue	Medium	Conduct tabletop exercise and establish 12-month testing cadence
<u>Oversee service providers</u>	Gap — annual questionnaire sent but SOC reports not consistently reviewed or tracked	High	Formalize vendor oversight process requiring annual SOC 2 review with escalation path
<u>Train employees on security awareness</u>	Compliant — annual training with phishing simulations	—	None
<u>Conduct a written risk assessment</u>	Compliant — annual NIST CSF 2.0-based assessment performed	—	None
<u>Encrypt customer information</u>	Partial — encryption in transit complete; encryption at rest incomplete	Medium	Complete encryption at rest rollout, prioritizing document imaging archive
<u>Implement and review access controls</u>	Partial — MFA enforced; periodic access recertification not formally scheduled	Medium	Establish quarterly access recertification process

Aa Safeguards Rule Element	≡ Current State	🕒 Severity	≡ Recommendation
<u>Monitor and log system activity</u>	Compliant — SIEM in place with defined alerting	—	None
<u>Designate a Qualified Individual</u>	Compliant — CISO formally designated	—	None